

ENGINEERING · GOVERNANCE

AI Acceptable Use Policy

POL-AI-AUP-002 · ฉบับภาษาไทย (คง technical terms เป็นภาษาอังกฤษ)

Document ID	POL-AI-AUP-002
Owner	VP Engineering / AI Governance Lead
Effective	16 กันยายน 2026
Review cadence	ทุก 6 เดือน หรือเมื่อ tool / กฎหมาย / agent-runtime เปลี่ยนสาระสำคัญ
Classification	Internal
Applies to	พนักงาน ผู้รับจ้าง และ agent ที่ใช้ระบบของบริษัททั้งหมด
Supersedes	POL-AI-AUP-001 (2026-09-16)

นโยบายการใช้ generative AI และ AI coding agent ในงาน product, engineering, design และการสื่อสารภายใน ยึดตาม NIST AI RMF (Govern / Map / Measure / Manage), NIST AI 600-1 (Generative AI Profile) และข้อกำหนดด้าน accountability ของ ISO/IEC 42001

1. Purpose

นโยบายนี้ให้บริษัทใช้ AI เป็น productivity coefficient โดยไม่เสีย ownership, accountability หรือ trust AI ร่างได้ มนุษย์ที่มีชื่อเป็นคน ship

มีขึ้นเพราะ unreviewed AI output ในโค้ด ดีไซน์ เอกสาร และ team chat ก่อให้เกิด slop, silent defect และพฤติกรรม meat-proxy คือคนส่งต่อ model output ที่อธิบายเองไม่ได้ สิ่งนี้ทำลายการร่วมงานเร็วกว่าบักก้อนเดียว

Version 002 เพิ่ม technical control ชัดเจนสำหรับ agent runtime (constitution, harness safety, CI gate) เพื่อให้ accountability บังคับใช้ได้ pipeline ไม่ใช่แค่ในวัฒนธรรม

2. Scope

นโยบายนี้ครอบคลุม generative AI และ agent tool ทั้งหมดที่ใช้กับงานบริษัท รวมถึงแต่ไม่จำกัดเพียง:

- Coding assistant และ agent (IDE, CLI, MCP, PR bot, multi-agent system)
- Chat model ที่ใช้สำหรับ design, เอกสาร, ticket, incident note และข้อความถึงลูกค้า
- Integration ที่โพสต์ AI output เข้า Slack, email, issue tracker หรือ docs
- Personal หรือ consumer account หากใช้กับงานบริษัท (โดยหลักห้าม ดู S6)
- Agent constitution file (agents.md, soul.md หรือเทียบเท่า) และ harness ที่โหลดไฟล์เหล่านั้น

นโยบายนี้ไม่แทน security, privacy, IP หรือ acceptable-use policy อื่น หากขัดกันให้ใช้กฎที่เข้มกว่า

3. Principles

- มนุษย์ที่มีชื่อเป็น author of record ของทุก artifact ที่ออกจาก workspace ของตน
- AI output ช่วยคิดและร่างได้ แต่ไม่แทน accountable judgment
- ถ้าอธิบายงานนั้นด้วยคำพูดตัวเองไม่ได้ นั่นไม่ใช่ assisted work แต่เป็นงานที่ outsource แล้ว และห้าม ship
- Team channel เป็นช่องของคน Bot ไม่ได้พูดในฐานะเพื่อนร่วมงาน
- มาตรฐาน quality, security, license และ review ใช้เท่ากับงานที่มนุษย์เขียนเอง AI ไม่ได้ลดมาตรฐาน
- Provenance บังคับเมื่อมันเปลี่ยน review path, incident response หรือ audit

7. Quality culture เป็น control การถ่ายงาน AI ทั้งก่อนไม่ใช่ความเร็ว แต่เป็นงานที่ไม่ผ่าน
8. (ใหม่ใน 002) Agent ที่สามารถเขียนโค้ดหรือ shared artifact ได้ต้องทำงานภายใต้ constitution ที่โหลดแล้ว ซึ่งบังคับ root-cause analysis, minimal change, ห้าม invented variable, ประกาศ dependency และ multi-agent safety Harness และ CI pipeline ต้องทำให้การละเมิดมองเห็นได้และ block ได้

4. Roles

Role	Accountability
Change owner (author)	คนที่มิชชีบน PR, เอกสาร, design หรือข้อความ เป็นเจ้าของ correctness, security, licensing และความสามารถในการอธิบายงาน
Reviewer	ทำ real review ไม่ใช่ owner เว้นแต่ pair มาด้วย ปฏิเสธ unexplained AI output หรือ constitution violation ได้
AI Governance Lead	เจ้าของนโยบายนี้, approved-tool register, มาตรฐาน agent-constitution, กระบวนการ exception และการทบทวนทุก 6 เดือน
Security / DevSecOps	ตรวจ vendor, คุม MCP และ data-exfil, implement CI gate, เส้นทาง incident จากช่องโหว่ที่ AI พาเข้ามา
Platform / Harness owner	ทำให้ multi-agent protocol ป้องกัน result overwrite และบังคับ constitution compliance check
Hiring manager	คัดเรื่อง ownership ไม่ใช่คิดว่าห้ามใช้ AI การบ้านต้องมี oral defense
People manager	ไม่ทน repeated slop สอนก่อน ถ้ายังถืองานเองไม่ได้ให้เข้ากระบวนการประเมินผลงาน

5. Approved, Restricted, Prohibited

5.1 Classification

Class	ความหมาย	ตัวอย่าง
Approved	ใช้ได้กับ data class และ use case ที่อยู่ใน register	Company-licensed Copilot / Claude / Cursor / internal model บน non-restricted repo โดย constitution ต้องโหลดสำหรับ write-capable agent
Restricted	ใช้ได้เฉพาะ use case ที่ระบุ หลังมี control เพิ่ม	Agent ที่มี repo write, production-adjacent MCP, customer-data summarization, multi-agent system
Prohibited	ห้ามใช้กับงานบริษัท	Consumer account กับ source หรือ confidential data; unknown MCP server; AI โพสต์ใน Slack แทนคน; agent ที่ ignore หรือโหลด constitution ที่กำหนดไม่ได้

Approved AI Tools Register เป็นแหล่งความจริงเดียว Tool ที่ไม่อยู่ในทะเบียนถือว่ายังไม่อนุมัติ วิธีขออยู่ใน S11

5.2 ข้อมูลที่ห้ามใส่ tool ที่ไม่ได้รับอนุมัติ

- Secret, credential, private key, session token
- Customer PII, payment data, health หรือข้อมูลที่ถูกกฎหมายกำกับอื่น
- Unreleased product strategy, unannounced security issue
- Source จาก repository ที่ทำเครื่องหมาย Restricted หรือสูงกว่า เว้นแต่ tool นั้นอนุมัติสำหรับ class นั้น
- ข้อมูลที่สัญญาลูกค้าห้ามส่งให้ third-party AI processor

6. Communication and Collaboration (No Meat Proxy)

หมวดนี้มีเพราะการให้ AI ส่งข้อความถึงเพื่อนร่วมงานโดยตรง ทำให้มองไม่เห็นว่ใครคิด และใครแค่กดส่ง

1. ห้ามต่อ AI assistant ให้ส่งข้อความตรงถึงเพื่อนร่วมงานใน Slack, email หรือ chat ในลักษณะพูดแทนคุณ

- ใช้ AI ร่างข้อความได้ แต่คุณเป็นคนส่ง และคุณเป็นเจ้าของข้อความนั้น
- ข้อความที่เสนอ design, การตัดสินใจ หรือการแก้โค้ด ต้องมี human rationale สั้น ๆ (ทำไมเลือกทางนี้ ตัดอะไรทิ้ง ความเสี่ยงที่เหลือ)
- Agent โพสต์สถานะใน dedicated bot channel ได้หากติดป้ายว่าเป็น bot แต่ห้ามพูดใน human standup, design thread หรือ incident command ในฐานะเพื่อนร่วมงาน
- คำว่า “The model said so” ไม่ใช่คำตอบที่ยอมรับได้ใน review, incident หรือ planning

7. Engineering Rules

7.1 Ownership

หาก username ของคุณอยู่บน commit, pull request, design doc หรือ ticket คุณคือเจ้าของ change Vendor ไม่ใช่เจ้าของ Reviewer ไม่ใช่เจ้าของ เว้นแต่ทำงานคู่กัน Agent เป็นเจ้าของไม่ได้เด็ดขาด

7.2 Provenance

ทุก PR ต้องประกาศหนึ่งอย่าง: Human-authored / AI-assisted / Agent-authored Label นี้ต้องเปลี่ยน review path เมื่อถึง threshold ใน §7.4 และเอกสาร CI Gates การติด label เท็จถือว่าผิด policy

7.3 Explain-or-it-does-not-ship

ก่อนขอ review เจ้าของงานต้องผ่าน self-review:

- อธิบาย diff ด้วยคำพูดตัวเองได้
- รู้ว่าทำไมเลือก design นี้ ไม่ใช่ทางที่เห็นได้ชัดอื่น
- มี test ครอบคลุม logic ใหม่ และมี rollback
- ตรวจ dependency, license และ secret แล้ว
- ยอม debug งานนี้ตอนที่สองได้

ถ้าข้อใดเป็นเท็จ ห้ามเปิด PR

7.4 Review path by risk

Tier	ตัวอย่าง	First response	Extra gate
Low	Docs, tests-only, tiny refactor	4 business hours	1 reviewer
Medium	Feature behind flag, small API	1 business day	Owner + 1 reviewer
High	Auth, payments, infra, migrations, PII	2 business hours	Owner + senior + security ตามกรณี
Agent-authored	PR ที่ agent เปิด ทุก tier	2 business hours	Named human owner + shepherd

7.5 Same bar as human code

Peer review, automated test, SAST/SCA, secret scan, dependency และ license review ใช้เหมือนกัน High-impact code, IaC และ policy logic ได้รับการ review เข้มข้นเสมอไม่ว่าใครพิมพ์

7.6 Agent Constitution & Harness (ใหม่ใน 002)

Agent ใดที่สามารถเขียนไปยัง repository หรือ shared artifact ได้ต้อง:

- โหลดและปฏิบัติตาม Agent Constitution ของบริษัท (agents.md / soul.md หรือ approved template ที่เทียบเท่า)
- ทำ root-cause analysis (What / How / Why) ก่อนเสนอการแก้โค้ด
- จำกัดการแก้ไขเฉพาะชุดไฟล์ขั้นต่ำที่จำเป็นต่อ root cause ที่ระบุ ห้ามลบไฟล์ที่ไม่เกี่ยวข้อง

- 4. ห้าม invent required variable, secret หรือ configuration value แนะนำได้เท่านั้นและรอ human confirmation
- 5. ประกาศการเปลี่ยนแปลง dependency หรือ version ใด ๆ พร้อม package name, old/new version และ rationale
- 6. เคราพ multi-agent safety protocol (ห้าม concurrent write ที่อาจ overwrite ผลลัพธ์)

Platform harness และ CI pipeline ต้องทำให้การละเมิด constitution มองเห็นได้และ block ได้ตามที่ configure จุดอ่อนของการรัน multi-agent พร้อมกัน (race condition, result overwrite) ถือเป็น control gap และต้อง remediate หรือ mitigate ด้วย sequential hand-off / locking

ข้อความ constitution ฉบับเต็มและกฎ CI gate อยู่ในเอกสารคู่: agents.md และ CI_Gates.md

8. Design, Documents, and Other Non-Code Artifacts

Slop ไม่ได้เกิดแค่ในโค้ด Spec, ADR, postmortem และเอกสารลูกค้าที่ model เขียนแล้วส่งต่อโดยไม่อ่าน อยู่ในขอบเขตนี้

- Named author ต้องป้องกันได้ทุก material claim, constraint และ trade-off
- ห้ามวาง model output ลง shared doc แบบ as-is โดยไม่มี human pass สำหรับข้อเท็จจริง ขอบเขต และโทน
- Citation และตัวเลขจาก model ถือว่ายังไม่ผ่านจนกว่าจะตรวจ

9. Hiring, Onboarding, and Performance

AI fluency เป็นสินทรัพย์เมื่อจับคู่กับ ownership เป็นภาระเมื่อบุคนั้นเป็นแค่ pass-through

- การบ้านใช้ AI ได้ แต่สัมภาษณ์ต้องมี oral defense: ทำไม design นี้ ทั้งทางไหน พังตรงไหน ทดสอบอย่างไร
- ส่งงานลื่นแต่คุยงานไม่ได้ เป็นสัญญาณไม่รับ
- หลังเข้างาน หากอธิบายงานที่ ship ด้วยความช่วยเหลือของ AI ไม่ได้ซ้ำ ๆ นั่นเป็นเรื่อง performance ไม่ใช่เรื่อง tooling
- อย่าให้รางวัลปริมาณ AI output ให้รางวัลผลที่ owner อธิบายได้

10. Risk Management, Audit, and Incidents

การใช้ AI ต้องมีแถวใน team risk register อย่างน้อยต้องมี (ไม่ครบถ้วน):

ID	ความเสี่ยง	Control ที่ใช้บ่อย
AIR-COM-01	AI โพสต์เข้า human channel โดยไม่มี sign-off	Bot-only channel, human ownership ของข้อความ
AIR-ACC-01	Author อธิบายงานที่ ship ไม่ได้	Explain-or-it-does-not-ship, oral defense
AIR-QUAL-01	Slop สะสมใน codebase / docs	PR size limit, AI% gate, mandatory test
AIR-SEC-01	Vuln / license / secret จากโค้ด AI	SAST/SCA + elevated review เมื่อ AI% สูง
AIR-AGENT-01	Agent แก่ไฟล์ไม่เกี่ยวข้องหรือ invent variable	Constitution + CI compliance gate
AIR-AGENT-02	Multi-agent result overwrite	Harness locking / sequential protocol
AIR-GOV-01	Shadow AI / personal account	Tool registry, ห้าม consumer account
AIR-OPS-01	ไม่มี provenance ตอนเกิด incident	Commit trailer, session metadata, AI-BOM

ทุกความเสี่ยงมี owner, คะแนน likelihood × impact, control, status และวันทบทวน

หลักฐานที่ต้องเก็บไว้ตอน audit:

- Approved tool register และ version
- PR provenance label และ review record
- ผล CI (รวม constitution และ dependency gate) และ exception log
- Metadata ระดับ session หรือ commit ถ้ามี
- Version ของ constitution ที่โหลดสำหรับ agent-authored change

Incident ที่เกี่ยวกับ AI-assisted หรือ agent-authored change เจ้าของคือ change owner ประโยค “The model generated it” หรือ “the agent did it” ไม่ใช่ root cause สิ่งทีขาดคือ control

11. New Tools and Exceptions

ขอเพิ่ม tool, high-risk use case หรือความสามารถใหม่ของ agent runtime ถึง AI Governance Lead: ชื่อ tool, use case, data class, เหตุผลทางธุรกิจ และ (สำหรับ write-capable agent) การยืนยันว่าสามารถโหลดและบังคับ constitution ที่กำหนดได้ คัดกรองภายในหัววันทำการ

- ความเสี่ยงต่ำ: Governance Lead อนุมัติได้
- Restricted data หรือ high-risk use (รวม multi-agent write system): Governance committee + privacy review ถ้ามี personal data

ตรวจ vendor ก่อนอนุมัติ: default training จากข้อมูลลูกค้า, retention/deletion, residency, SOC 2 หรือ ISO 27001, DPA, breach notification Tool ที่เทรนจาก prompt เป็นค่าเริ่ม ไม่อนุมัติกับ company source หรือ confidential data

Temporary exception ต้องเขียนเป็นลายลักษณ์ มี time-box และลงสมุด Personal consumer account ไม่ใช่ทางลัดสำหรับ source หรือ confidential data

12. Violations

ตัวอย่างการละเมิด:

- ส่ง model output ให้เพื่อนร่วมงานในฐานะวิเคราะห์ของตน
- Merge โค้ดที่อธิบายไม่ได้
- ใส่ secret หรือข้อมูลลูกค้าใน tool ที่ไม่ผ่าน
- ปิดป้าย AI เมื่อ policy บังคับให้ติด
- ปิด scanner หรือ CI gate ที่จำเป็นเพื่อให้ AI output ผ่าน
- รัน write-capable agent โดยไม่มี constitution ที่กำหนด
- ปลอมให้ multi-agent overwrite ที่ harness ป้องกันไม่ได้
- Invent required variable หรือเปลี่ยน dependency โดยเจียบ

การจัดการตามสัดส่วน: สอนและ revert ก่อน จำกัดสิทธิ์ กระบวนการผลงาน หากจงใจทำข้อมูลรั่วให้เข้า security incident process

13. Metrics

Leadership ทบทวนอย่างน้อยรายไตรมาส ปริมาณการใช้ AI ไม่ใช่ success metric โดยลำพัง

- สัดส่วน PR ที่มี provenance label ตรงความจริง
- Constitution compliance pass rate ในการ submit ครั้งแรก
- เวลา review และ acceptance rate ของงาน AI-heavy เทียบงานที่มนุษย์เขียน
- Defect และ vuln ที่พบหลัง merge แยกตาม provenance
- อัตรา undeclared dependency change
- จำนวน exception และ shadow-tool finding
- จำนวน incident ที่ owner อธิบายงานไม่ได้
- จำนวน multi-agent conflict / overwrite incident

14. Related Control Set

- NIST AI RMF 1.0 และ Generative AI Profile (NIST AI 600-1) — Govern, Map, Measure, Manage

- ISO/IEC 42001 — AI management system (roles, risk treatment, internal audit)
- นโยบายความมั่นคงปลอดภัย ข้อมูลส่วนบุคคล และทรัพย์สินทางปัญญาของบริษัท
- Approved AI Tools Register (เอกสารที่มีชีวิต)
- AI risk register workbook
- Agent Constitution (agents.md / soul.md) — บังคับสำหรับ write-capable agent
- CI Gates document — บังคับ AI%, constitution compliance, dependency pin และ risk-tiered review

15. Acknowledgement

การใช้ระบบบริษัทและ AI tool กับงานบริษัท หมายความว่าคุณคือ author of record ของสิ่งที่คุณส่ง commit และ ship AI ไม่ถือ pager คุณถือ

Agent ที่โหลด constitution ของบริษัท ยอมรับว่าการละเมิดเป็น policy breach และต้องแจ้งให้ human change owner ทราบ

Document Control

Version	วันที่	หมายเหตุ
1.0	2026-09-16	นโยบายเริ่มต้น: ownership, ห้าม AI-to-teammate posting, provenance, risk-tiered review, hiring defense, audit evidence
2.0	2026-09-16	เพิ่มข้อกำหนด agent constitution, harness multi-agent safety, CI gate สำหรับ AI% + constitution compliance + dependency pin, ขยายแถว risk register และเอกสารคู่ agents.md + CI_Gates.md

Appendix A — ใบรับทราบและลงนาม

ข้าพเจ้าได้รับ อ่าน และเข้าใจนโยบาย POL-AI-AUP-002 (AI Acceptable Use Policy) รวมทั้ง Approved AI Tools Register และข้อกำหนด Agent Constitution ที่ใช้อยู่ในขณะลงนาม

ข้าพเจ้ารับว่า:

- งานที่ข้าพเจ้าส่ง commit หรือเผยแพร่ ข้าพเจ้าเป็น author of record แม้ AI จะช่วยร่าง
- ข้าพเจ้าจะไม่ให้ AI ส่งข้อความถึงเพื่อนร่วมงานแทนตน
- ข้าพเจ้าจะไม่นำ secret, ข้อมูลลูกค้า หรือ Restricted source ใส่ tool ที่ไม่อนุมัติ
- ข้าพเจ้าจะติดป้าย provenance ตามจริง และจะไม่ ship งานที่อธิบายเองไม่ได้
- Write-capable agent ที่อยู่ภายใต้การควบคุมของข้าพเจ้าจะโหลดและปฏิบัติตาม constitution ที่กำหนด
- หากไม่เข้าใจข้อใด ข้าพเจ้าจะถาม AI Governance Lead ก่อนใช้ tool หรือความสามารถ agent ใหม่

ข้อมูลผู้ลงนาม

ช่อง	ค่า
ชื่อ-นามสกุล	
ตำแหน่ง / ทีม	
อีเมลบริษัท	
ผู้บังคับบัญชา	
วันที่รับทราบ	
เวอร์ชันนโยบายที่รับทราบ	2.0 (2026-09-16)

เก็บใบนี้ไว้กับ HR / Governance คู่กับบันทึก onboarding การไม่ส่งใบนี้ไม่ทำให้พ้นจากนโยบาย หากใช้ระบบบริษัทถือว่าผูกพันตาม §15

End of POL-AI-AUP-002